

Report di Sicurezza: Analisi di Vulnerabilità e Comprensione degli Hash

1. Obiettivo dell'Esercizio

L'attività ha avuto come scopo l'analisi di una vulnerabilità di tipo **SQL Injection (SQLi)** all'interno della web application DVWA, finalizzata all'estrazione di dati sensibili dal database e alla successiva analisi delle credenziali tramite attacchi di tipo *password cracking*.

2. Fase di Ricognizione ed Exploit (SQL Injection)

Attraverso la manipolazione del campo di input "User ID", è stata verificata la presenza di una falla di sicurezza. Inserendo una query di tipo **UNION SELECT** è stato possibile interrogare direttamente il database, bypassando le normali procedure di autenticazione.

- **Query utilizzata:** `1' UNION SELECT user, password FROM users --`
- **Risultato:** Il database ha restituito l'elenco completo degli utenti e dei relativi hash MD5 associati.

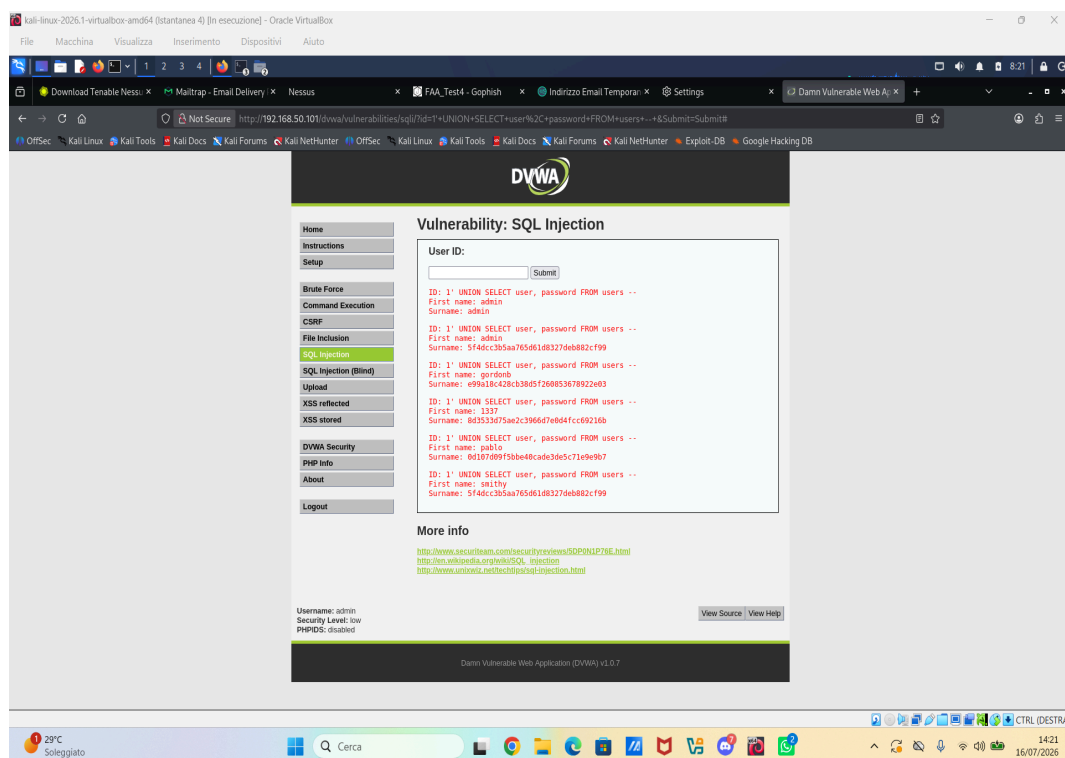


Figura 1: Estrazione degli hash tramite SQL Injection.

3. Fase di Analisi Crittografica

Gli hash estratti dal database sono stati identificati come stringhe in formato **MD5**. Tale identificazione è confermata dalla struttura stessa delle stringhe ottenute, che presentano le caratteristiche tipiche degli hash MD5:

- **Rappresentazione Esadecimale:** Ogni hash è composto esclusivamente da caratteri alfanumerici che spaziano da **0 a 9** e da **a ad f**.
- **Lunghezza:** Si presentano come stringhe di lunghezza fissa (32 caratteri), che è lo standard per l'output di questa funzione di hashing.
- **Debolezza:** È stato osservato che tale algoritmo, essendo obsoleto e non protetto da *salt*, risulta altamente vulnerabile a tecniche di cracking basate su dizionari e calcolo massivo, poiché la sua struttura prevedibile e la velocità di elaborazione non offrono una resistenza adeguata contro i moderni attacchi offline.

4. Fase di Post-Exploitation (Password Cracking)

Per recuperare le password in chiaro, è stato utilizzato il tool **John the Ripper**. Il processo si è svolto in due fasi:

1. **Attacco a dizionario:** Grazie alla semplicità delle password, il tool ha risolto quasi istantaneamente la maggior parte degli hash.
2. Per le credenziali residue, il software è passato autonomamente alla **modalità incrementale** (brute force), garantendo la risoluzione completa del set di dati.

I risultati ottenuti sono riassunti nella seguente tabella:

Username	Hash (MD5)	Password in chiaro
admin	5f4dcc3b5aa765d61d8327deb882cf99	password
gordonb	e99a18c428cb38d5f260853678922e03	abc123
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein
smithy	5f4dcc3b5aa765d61d8327deb882cf99	password

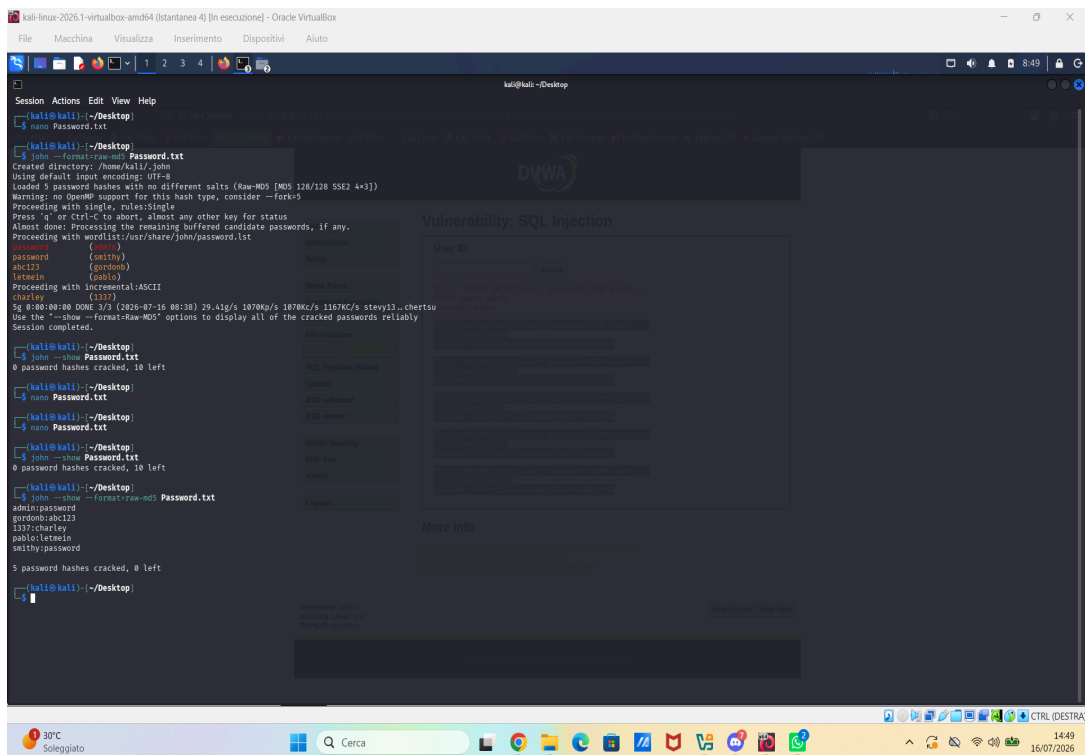


Figura 2: Output del tool John the Ripper con le credenziali decodificate.

5. Conclusioni e Raccomandazioni

L'esercizio ha dimostrato come una singola vulnerabilità applicativa (SQLi) possa compromettere l'intero database utenti.

- **Raccomandazione 1:** Implementare la *prepared statement* o la sanificazione dell'input per prevenire iniezioni SQL.
- **Raccomandazione 2:** Abbandonare l'algoritmo MD5 in favore di algoritmi moderni come **bcrypt** o **Argon2**, che includono nativamente l'uso di *salt* per prevenire attacchi di cracking offline.